

FUTURE INTERNS



PHISHING EMAIL DETECTION & AWARENESS REPORT

Prepared By:

Jennifer Kate Dsouza



WHY PHISHING STILL WORKS IN 2026

Most people assume cyberattacks happen because of some highly technical exploit — a hacker breaking through layers of firewalls or cracking complex encryption. The reality is far simpler and, honestly, a lot scarier. The majority of successful attacks today start with a single email that lands in someone's inbox and looks completely legitimate.

Phishing is a social engineering technique where attackers impersonate trusted individuals or organizations to manipulate users into handing over sensitive information. They're not hacking the system — they're hacking the person. And it works incredibly well because it targets human instinct: urgency, fear, and trust.

This report analyzes three phishing email examples, breaks down the red flags in each one, explains how each attack is designed to work, and wraps up with practical prevention guidelines that any employee can actually follow — not just security teams.





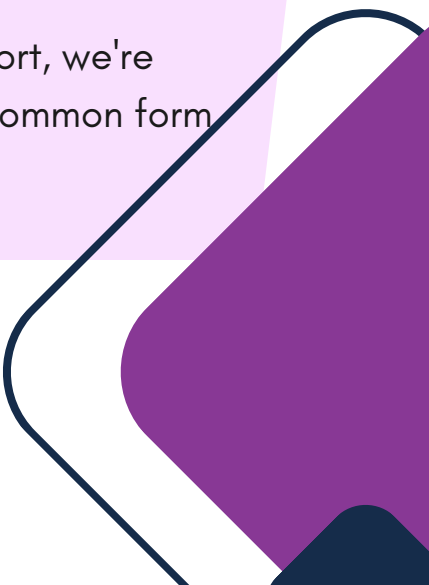
UNDERSTANDING THE ATTACK

Phishing is when an attacker sends a fake email pretending to be someone you trust, your bank, your IT department, a courier service, or even your company's CEO.

The goal is almost always one of three things: get you to click a **malicious link**, download a **file laced with malware**, or hand over login **credentials or OTPs directly**.

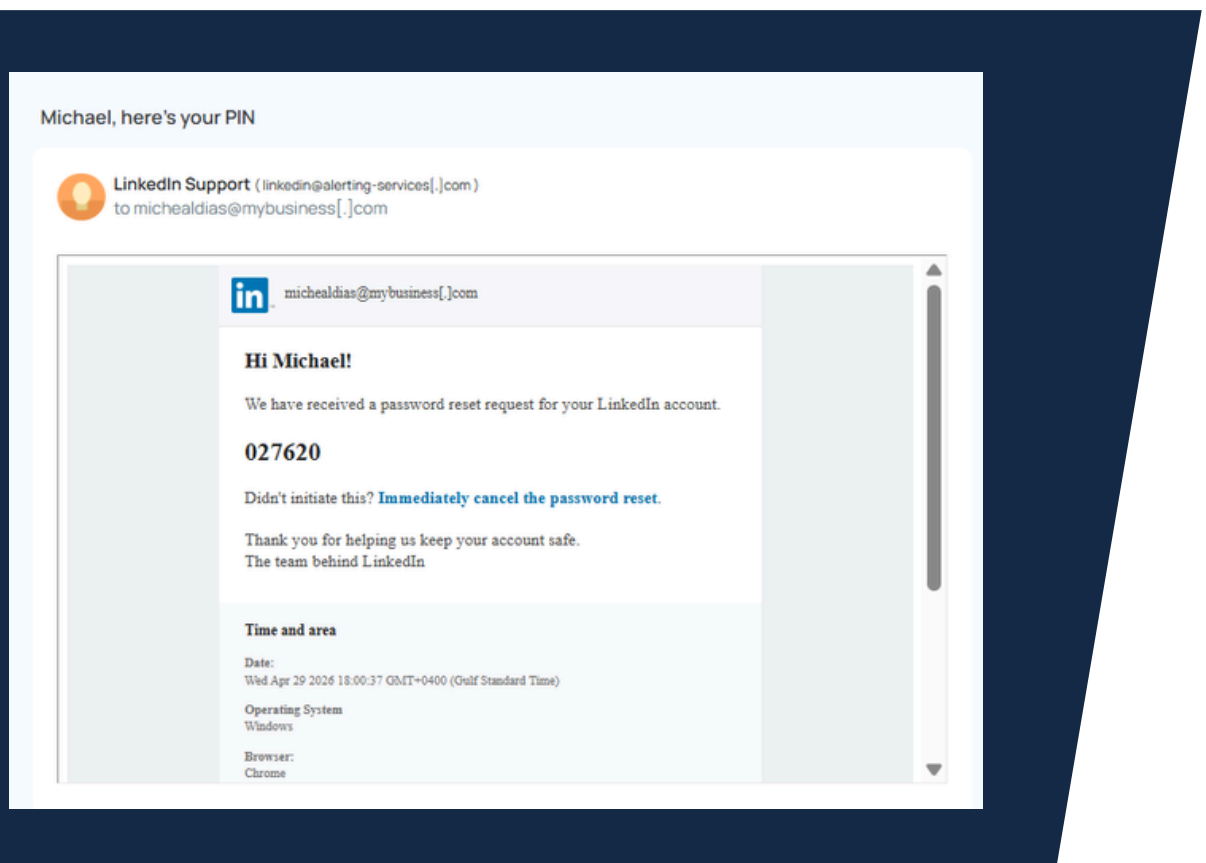
What makes phishing dangerous isn't sophistication, it's believability. Modern phishing emails are well-designed, use real company logos, and are written to sound professional. The tell-tale signs are subtle, and most users don't know what to look for. That's exactly what this report is meant to fix.

There are a few common variations worth knowing:

- **Spear phishing** is targeted at a specific individual using personal details.
 - **Whaling** targets executives.
 - **Smishing** uses SMS instead of email. For this report, we're focusing on standard email phishing — the most common form businesses encounter.
- 

EXAMPLE #1

LINKEDIN PASSWORD RESET PIN SCAM



LINKEDIN PASSWORD RESET PIN SCAM

RED FLAGS IDENTIFIED

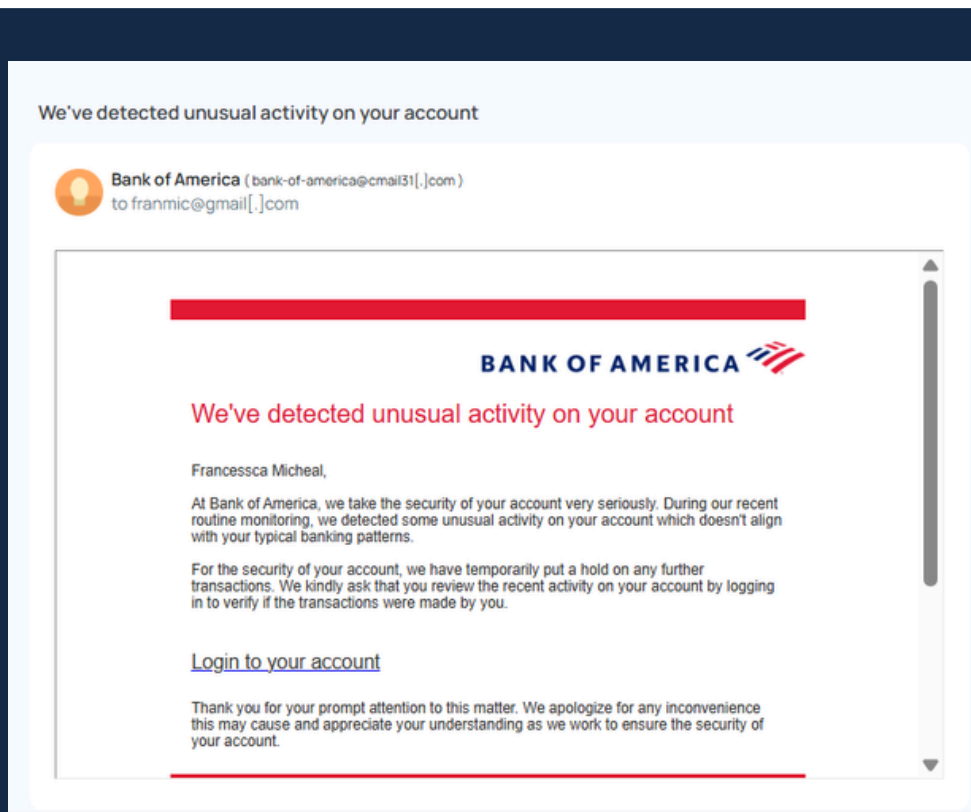
- **Spoofed Sender Domain**
 - The email displays "LinkedIn Support" as the name, but the actual address is linkedin@alerting-services[.]com — completely unrelated to LinkedIn's real domain (linkedin.com). This is a classic display-name spoofing trick.
- **Malicious "Cancel" Link**
 - "Immediately cancel the password reset" is a trap. Clicking it doesn't cancel anything — it takes you to a fake LinkedIn page designed to harvest your credentials.
- **Unsolicited PIN Delivery**
 - A PIN being emailed to you means someone triggered a password reset on your account. The attacker initiates the reset themselves, then hopes you use the PIN — giving them control of the reset flow.
- **Targeted with Real Name & Location**
 - The email uses the recipient's real name ("Michael") and shows a real timestamp and location. This personal detail makes it feel legitimate — but that data is often scraped from public profiles.

HOW THIS ATTACK WORKS

- **Attacker triggers a real LinkedIn password reset on the target's account**
 - This causes LinkedIn to send an official PIN to Michael's email — giving the attack a veneer of legitimacy.
- **A spoofed "LinkedIn Support" email is sent alongside it**
 - The phishing email mimics LinkedIn's notification format and delivers the same PIN, with a fake "cancel" link embedded in it.
- **Target clicks "cancel" or provides the PIN on a phishing page**
 - Either action redirects Michael to a fake LinkedIn login where his credentials are captured.
- **Account is taken over**
 - With the credentials or the PIN, the attacker completes the reset and gains full control of the LinkedIn account.

EXAMPLE #2

BANK OF AMERICA UNUSUAL ACTIVITY ALERT



BANK OF AMERICA UNUSUAL ACTIVITY ALERT

RED FLAGS IDENTIFIED

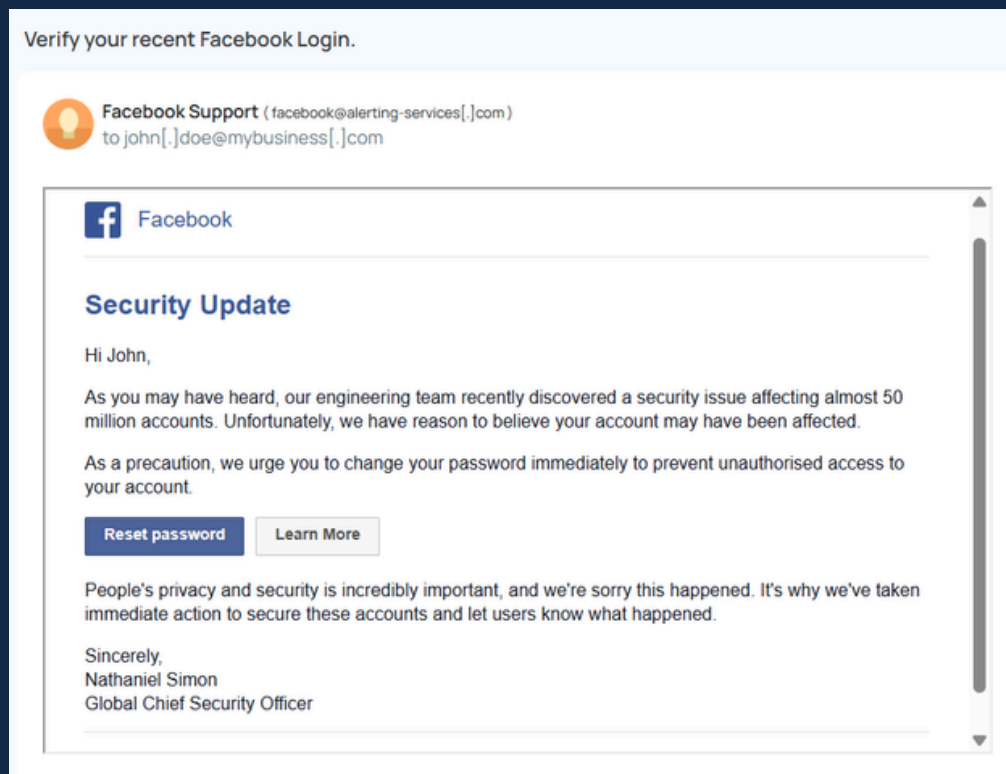
- **Fake Sender Domain**
 - Bank of America's real emails come from @bankofamerica.com. This email originates from @cmail31[.]com — a completely unrelated bulk-mail domain. The display name "Bank of America" is forged.
- **Fear-Based Urgency: Account on Hold**
 - Claiming a "hold on transactions" creates immediate fear. The goal is to make you act fast, bypassing rational thought and going straight to clicking the login link.
- **Misspelled Recipient Name**
 - The email addresses "Francessca Micheal" — a misspelling of the real name "Francesca Michael." Legitimate banks pull exact names from verified account records. This error suggests a data-list was used.
- **Generic "Login to your account" Link**
 - Legitimate bank alerts include the last 4 digits of your account number and link directly to bankofamerica.com. A vague hyperlinked phrase with no visible URL is a hallmark of credential-harvesting pages.

HOW THIS ATTACK WORKS

- **Mass email sent impersonating Bank of America**
 - The email is blasted to thousands of addresses. Some of them will genuinely be Bank of America customers, making the scam plausible.
- **Recipient clicks "Login to your account"**
 - The hyperlink redirects to a cloned Bank of America login page — visually identical to the real one, hosted on a fraudulent domain.
- **Banking credentials entered on the fake page**
 - Username, password, and possibly a one-time code are captured by the attacker in real time.
- **Account drained or used for fraud**
 - With full banking access, attackers can transfer funds, change account details, or sell credentials on the dark web.

EXAMPLE #3

FACEBOOK SECURITY UPDATE SCAM



FACEBOOK SECURITY UPDATE SCAM

RED FLAGS IDENTIFIED

- **Same Fake Domain as Example #1**
 - This email comes from @alerting-services[.]com — the exact same third-party domain used in the LinkedIn scam (Example #1). This is a phishing infrastructure serving multiple impersonations simultaneously.
- **Fabricated Mass Security Breach**
 - Referencing "50 million affected accounts" is a scare tactic designed to make the claim feel credible and the threat feel enormous. No such breach is named or verified — the number is chosen to induce panic.
- **Fake Authority Figure**
 - "Nathaniel Simon, Global Chief Security Officer" is a fabricated name. Facebook's real security communications never include the personal name and title of an executive at the bottom of a mass email.
- **Malicious "Reset Password" Button**
 - The "Reset password" button does not link to facebook.com. It redirects to a phishing page that clones Facebook's interface to steal the victim's current credentials under the guise of a reset.

HOW THIS ATTACK WORKS

- **Attacker references a real or fictional past breach for credibility**
 - Facebook has had real breaches before. Referencing a large number (50 million) exploits public memory and makes the claim seem believable without any verification.
- **Victim clicks "Reset password"**
 - The button's link, if hovered over, would reveal a non-Facebook URL. Most users don't check — they just click.
- **Cloned Facebook page asks for current credentials**
 - The fake page looks exactly like Facebook's login or password-change screen. The user enters their current password believing they're securing their account.
- **Account taken over; used for scams or sold**
 - With Facebook access, attackers can impersonate the victim, send scam messages to friends, or sell the account credentials for profit.

COMMON PHISHING INDICATORS AT A GLANCE

Across all three email samples, the same patterns keep showing up. Here's a consolidated reference of what to look for in any suspicious email.

INDICATOR	WHAT IT LOOKS LIKE	WHY IS IT USED
Spoofed Sender Domain	Display name says "LinkedIn" or "Bank of America" but the actual email is @alerting-services.com or @cmail31.com	Makes the email appear to come from a trusted source at first glance
Urgency / Threat Language	"Unusual activity detected," "account on hold," "change your password immediately"	Bypasses rational thinking by triggering panic or fear
Credential Harvesting Links	"Login to your account," "Reset password," "Cancel the password reset" — all linking to fake pages	Redirects victim to cloned pages designed to steal usernames and passwords
Real Name Targeting	Emails address "Michael" or "John" by name to seem personal and legitimate	Names scraped from data breaches or public profiles add a false sense of authenticity
Shared Infrastructure	Example #1 and #3 both use @alerting-services[.]com despite impersonating different companies	Same phishing kit deployed to target multiple platforms simultaneously
Fabricated Authority	"Nathaniel Simon, Global Chief Security Officer" signed at the bottom	A named executive makes the email seem more official and harder to question
Unverifiable Claims	"50 million accounts affected" with no verifiable source or incident name	Large, scary numbers create urgency without requiring proof
Typos & Name Errors	"Francesca Micheal" instead of the correct name spelling	Indicates bulk targeting from a scraped list rather than a legitimate account database

WHAT EMPLOYEES SHOULD KNOW

Security systems can block a lot of threats, but they can't block everything — and attackers know this. The goal of phishing is to get a human to do the thing the system would block. These guidelines are written for real people, not security professionals.

DO'S

- Hover over all links before clicking — check the actual URL, not just the display text
- Check the full sender email address, not just the display name shown in bold
- If you get an unexpected PIN or security code, treat it as a sign someone is attempting to access your account — do not use it
- Verify security alerts by going directly to the platform's website — type the URL yourself, never click the email link
- Report suspicious emails to your IT or security team immediately
- Enable two-factor authentication on all important accounts

DON'TS

- Don't trust an email just because it uses your real name — that data is widely available
- Don't click "cancel," "reset," or "verify" links in security alert emails — go to the site directly instead
- Don't assume an email is safe because it has a professional logo or formatting
- Don't enter your current password on any page reached via an email link
- Don't trust large scary numbers ("50 million accounts") without verifying the claim independently
- Don't keep quiet if you think you've been tricked — report it fast so accounts can be secured

FINAL THOUGHTS

The three emails analyzed in this report all impersonate major, trusted platforms — LinkedIn, Bank of America, and Facebook. In each case, the attacker exploited the same core human responses: trust in recognizable brands, fear of losing account access, and urgency that pushes people to act before thinking. What makes these attacks effective isn't technical complexity — it's psychological precision.

Notably, Examples #1 and #3 share the same sending infrastructure (@alerting-services[.]com), demonstrating that a single phishing operation can simultaneously impersonate multiple companies using the same domain. This is a reminder that attackers operate at scale, and even a low success rate across millions of emails translates into real harm.

The good news is that awareness dramatically reduces risk. Once you know to check the actual sender address — not just the display name — and to navigate to platforms directly rather than through email links, these attacks lose their power. Security is a habit, not a feature.

The most important takeaway from this report isn't any specific red flag — it's the habit of pausing for just a few seconds before clicking anything in an email. That pause is often enough to catch what the attacker is hoping you'll miss.